Rapport d'audit global du projet

Date de rédaction initiale : 28 octobre 2026 - **Périmètre de l'inventaire actualisé :** fichiers versionnés du checkout courant, pas la copie locale ni les fichiers ignorés de l'utilisateur. [Inventaire exhaustif des chemins](17-inventaire-projet.csv) - [Revue initiale du code potentiellement inutilisé](16-audit-code-mort.md) - [Todolist](10-todo-corrections.md).

L'inventaire couvre **539 chemins versionnés** dans le périmètre révisé : 498 au SHA de base audité (`b54ab9833eb5e7d5116a21a1f21cb3b7c845eb31`), moins `.gitlab-ci.yml`, plus quatre rapports (`docs/19-docs/22`), 36 rendus HTML/PDF/DOCX ajoutés pour les documents qui n'avaient pas encore ces formats versionnés et les deux fichiers de la page de diagnostic staging. Le total précédent de **402** ne correspondait pas au CSV exhaustif ni au nombre de chemins retournés par `git ls-tree`; il est remplacé. Le contrôle structurel confirme la présence et la non-vacuité des fichiers suivis, sans certifier leur contenu.

Cet audit combine un inventaire automatisé de tout le dépôt et une revue manuelle ciblée sur les anomalies et risques découverts. Il **ne démontre pas l'absence de tous les défauts** et n'est pas une lecture fonctionnelle ligne par ligne de chaque livrable. L'inventaire indique des contrôles de structure, pas une certification du contenu.

Constats corrigés

Élément	Problème et correction	Vérification
Journal JSON	`tail(0)` retournait tout le journal, une limite négative donnait un résultat incohérent. Une limite <= 0 renvoie `[]`. La doc n'affirme plus qu'un écran back-office le consulte.	Tests sur journal temporaire : absent, zéro, négatif, ordre, limites et ligne JSON invalide.
Provisionnement SQL	Les générateurs publics concaténaient des noms ou un mot de passe non validés. Ils refusent maintenant les identifiants dangereux ; le mot de passe doit provenir de `DbProvision::motDePasse()` (32 hexadécimaux). Le provisioning vérifie aussi la présence de `sudo` avant création du fichier temporaire.	Tests de génération seule avec entrées d'injection, sans exécuter SQL ni sudo.
E2E	La photographie/restauration pouvait écraser des modifications concurrentes ou échouer après interruption. L'E2E crée son jeu de démonstration dans le FS PHP-WASM uniquement : pas de chargement ni rapatriement du dossier `data/` hôte. L'ancien utilitaire est conservé mais avertit de son danger.	303 contrôles HTTP WASM réussis en copie jetable contenant trois fichiers hôte témoins inchangés. Pas de navigateur.
Tests SQL	L'ancien test supprimait silencieusement sa cible, y compris une base existante ou celle de l'application si configurée comme cible. Il refuse `DB_NAME`, crée une base absente atomiquement, et n'autorise une réinitialisation qu'avec l'option explicite `--reinitialiser-base-existante`.	Garde-fous, intégration et 29 scénarios réussis sur le serveur MySQL jetable de la CI du commit `796aada`. Aucun serveur SQL local n'a été touché.

Tests nouveautés SQL	Le test partagé effectuait deux mises à jour sans condition, refusées par le pilote SQL. Il utilise désormais une condition explicite sur la clé primaire, sans supprimer la protection du pilote.	Cas JSON rejoué localement ; validation MySQL en CI sur base jetable.
Contrat HTTP	Un test affirmait tester « 403/500 » en cherchant seulement `page404` ou `erreur`. Il vérifie désormais le code et la vue 500 ; la garde SUPER déclenche désormais une réponse 403 et la page dédiée ; les visiteurs non connectés restent redirigés vers la connexion.	309 contrôles E2E WASM ; tests HTTP natifs ajoutés en CI. Contrat 500 statique, pas une injection d'erreur 500 réelle.
Git / sécurité	Les variantes `.env.*`, certificats P12/PFX et clés privées usuelles sont ignorés, sauf le modèle `.env.example` à la racine. Le scan reconnaît les worktrees Git (`.git` fichier) et les PFX.	Test d'ignore en dépôt temporaire ; scan complet exécuté depuis un worktree temporaire ; scan et autotest sécurité. Les règles `.gitignore` n'enlèvent pas un secret déjà suivi ni dans l'historique.
Test des montants	Le seed JSON ne contient pas de commande : le test des montants parcourait des listes vides sans assertion. Il crée maintenant deux commandes réelles de montants différents et vérifie explicitement les lignes et totaux.	Exécuteur PHPUnit local ; validation native par CI.
PHPUnit natif	Le commentaire du fichier `phpunit.xml` contenait `--`, interdit en XML : PHPUnit arrêtait avant les tests. Commentaire corrigé et contrôle XML structurel ajouté.	Validation PHPUnit natif en CI ; exécuteur local WASM ne lit pas ce XML.
Chargeur SQL CLI	`scripts/load_db.php` appelait récursivement son propre gestionnaire d'erreur quand `STDERR` existe ; il écrit maintenant sur `STDERR`.	Test natif d'un nom de base invalide, sans connexion SQL ni écriture.
CI GitHub Actions	Le workflow `.github/workflows/ci.yml` porte les contrôles SQL/PHPUnit et les suites isolées ; aucun fichier/configuration de CI GitLab n'est conservé dans le périmètre courant. Le style reste explicitement non bloquant selon le workflow.	Les runs cités dans ce rapport sont des résultats GitHub Actions sur les commits indiqués ; ils ne prouvent ni un pipeline GitLab IUT ni l'approbation d'une MR GitLab.
11 candidats	Analyse détaillée dans `docs/16-audit-code-mort.md`. `Filter::isNotNull`, `Journal::tail`, `JsonTable::isDirty` ont des tests ; `sudoDisponible` est réellement utilisé. `page403` est appelée ; `withStore`, `dsnUtilise`, `codeDerniereErreur` et `EnvFile::existe` ont été retirées sur demande ; `comptesDemo` est appelée par la nouvelle aide CLI et `$nom` a été remplacé par une alternative de visuel. Aucune des alertes initiales ne reste dans le référentiel ; cela ne prouve pas l'absence de code inutilisé.	`for()` est conservée et testée ; tout consommateur externe de `withStore()` doit migrer vers `CommandeRepository::for($store)`.

Alternatives d'image et aide CLI

`visuel_produit($url, $alternative, $largeur, $hauteur)` reçoit une `AlternativeImage` : utiliser `new \App\View\Image\AlternativeDecorative()` pour une image décorative ou `new \App\View\Image\AlternativeInformative($description)` pour une image informative. La

description est obligatoire et échappée. Les anciennes signatures avec le nom en deuxième position doivent être adaptées ; les cartes conservent `alt=""`. La fiche identifie le visuel comme indicatif, mais ne décrit pas son apparence. Le choix de la stratégie est explicite à l'exécution.

`php scripts/aide.php --help` est une aide en lecture seule. `--comptes-demo` affiche les identifiants initiaux du seed JSON, potentiellement absents ou modifiés localement ; le script refuse l'accès HTTP et ne vérifie ni n'initialise la base. Ne pas laisser les comptes de démo actifs sur une instance accessible sans protection.

Accesseur de code d'erreur SQL supprimé

`DbInstaller::codeDerniereErreur()` a été retirée sur demande. Le code privé reste exploité par `refusIdentifiants()` et par les diagnostics d'installation. Un test sans serveur injecte les codes 1045, 1698, 2002 et 0 pour vérifier leur classement ; il ne simule pas une connexion PDO réelle. [CI du commit `4860daa` verte](https://github.com/jojo8356/SAE-302/actions/runs/40838583689), y compris PHP natif 8.2/8.5 et MySQL 8 jetable. La méthode était publique : les appels externes éventuels doivent être adaptés.

Accesseur de vérification `.env` supprimé

`EnvFile::existe()` a été retirée sur demande. `initialiser()` vérifie toujours elle-même l'existence du fichier avant toute écriture. Des tests utilisent un fichier temporaire pour contrôler création et non-écrasement. [CI du commit `690a2fe` verte](https://github.com/jojo8356/SAE-302/actions/runs/40843062586), dont PHP natif 8.2/8.5 et MySQL 8 jetable. Les appels externes à la méthode supprimée doivent être adaptés. Le scanner ne relève plus de candidat dans son périmètre, ce qui ne prouve pas l'absence de code inutilisé.

Couverture par famille

- `app/`, `public/` : inventaire détaillé des 147 fichiers dans `docs/16-audit-code-mort.md`, revue ciblée des 11 candidats, contrats PHP, sécurité, parcours HTTP WASM. Le rendu visuel réel et tous les chemins ne sont pas démontrés.
- `scripts/`, `tests/`, CI et configuration racine : examen ciblé des runners, du provisionnement, de l'E2E, des tests SQL et des garde-fous Git ; syntaxe des scripts couverte par les contrôles ci-dessous. Certains outils d'installation, sauvegarde, déploiement, capture et performance peuvent modifier des données : usage sur environnement isolé, après lecture de leurs options.
- `sql/`, `tests/sql/` : fichiers inventoriés, scénarios et appels dangereux examinés. Les SQL directs peuvent réinitialiser leurs bases. La campagne SQL réelle n'a pas été lancée dans cette sandbox ; voir le résultat de la CI MySQL isolée, qui ne remplace pas MariaDB ni LineServ.
- `data/`, `uploads/`, ressources : fichiers inventoriés, JSON et SVG analysés structurellement. Les données de démo ne doivent pas être utilisées comme comptes actifs en production. Aucun contenu de compte n'est reproduit ici ; fichiers locaux ignorés et non suivis hors périmètre.

• `docs/`, `livrables/`, `artefacts/`, `.tools/`, `.gitlab/` : inventaire et contrôles de structure applicables, documentation des risques et rapports mis à jour. Les documents bureautiques sont testés comme archives ZIP, **pas** relus intégralement ni validés par affichage ; PDF, images, diagrammes et livrables ne sont pas tous contrôlés visuellement.

Validation CI

[CI GitHub historique du commit `796aada`](https://github.com/jojo8356/SAE-302/actions/runs/40759093253) : succès des suites isolées en PHP natif 8.2 et 8.5, des contrôles de sécurité, du véritable PHPUnit, des 303 contrôles E2E WASM et de MySQL 8 isolé (29 scénarios, intégration et garde-fous). Le contrôle de style reste non bloquant. Cette validation est antérieure au branchement de la page 403 ; la CI du nouveau commit doit être vérifiée séparément. Elle ne couvre ni MariaDB ni navigateur réel.

Page 403 - validation du commit `01cc0fa` : [CI verte](https://github.com/jojo8356/SAE-302/actions/runs/40773408401), y compris les parcours HTTP natifs sur PHP 8.2 et 8.5, l'E2E WASM isolé, PHPUnit, sécurité et MySQL 8 jetable. Le test natif utilise un serveur et des données temporaires ; le rendu dans un navigateur et sur LineServ reste à vérifier.

Suppression de `withStore` - validation du commit `839e311` : [CI verte](https://github.com/jojo8356/SAE-302/actions/runs/40775475513), dont PHPUnit natif, suites PHP 8.2/8.5, E2E WASM et MySQL 8 jetable. La migration éventuelle des appels extérieurs reste à la charge de leurs utilisateurs.

Aide CLI et alternatives d'image - validation du commit `30b4c8a` : [CI verte](https://github.com/jojo8356/SAE-302/actions/runs/40835999534) en PHP natif 8.2/8.5, avec tests CLI en copie jetable et refus HTTP, PHPUnit, sécurité, E2E WASM et MySQL 8 jetable. Le rendu et la pertinence des descriptions restent à valider sur navigateur et contenus réels.

Contrôles automatisés disponibles

`tests/python/test_audit_structurel.py` prend la liste `git ls-files` et vérifie présence/non-vide, synchronisation de l'inventaire CSV, compilation Python sans exécution, analyse JSON, XML et SVG, intégrité interne ZIP des formats bureautiques, `bash -n` et `node --check` si présents. Il ne vérifie ni le comportement ni la qualité visuelle, et n'ouvre pas les fichiers ignorés. Les scripts PHP sont analysés séparément par `scripts/verifier_deprecations.py` et la CI.

• Sandbox : suites isolées PHP-WASM 8.2 vertes, dont 43 tests PHPUnit avec l'exécuteur local ; analyse PHP-WASM 8.5.10 sur 10 fichiers PHP modifiés sans erreur de syntaxe ou dépréciation détectée. Le code de retour WASM n'est pas une preuve native ; diagnostics examinés et CI native nécessaire.

• E2E : 309 vérifications réussies sans navigateur, données témoins inchangées. Security scan : 10 contrôles et autotest conformes. Tests structurels Python conformes.

• PHP natif, navigateur réel/WAVE, MariaDB et LineServ : **non joués dans cette sandbox**. La

CI éventuelle utilise MySQL 8, pas MariaDB. Les anciennes campagnes ou mesures datées des autres documents restent historiques.

Risques restants et auto-évaluation

1. La page 403 est branchée pour le refus SUPER ; l'intégration navigateur réelle reste à vérifier. La suppression de `withStore` est une rupture pour les usages externes éventuels : remplacer `$depot->withStore($store)` par `CommandeRepository::for($store)`. `dsnUtilise`, `codeDerniereErreur` et `EnvFile::existe` ont été supprimées et la signature de `visuel_produit` a changé : les appels externes doivent être adaptés. La fiche identifie le visuel comme indicatif ; ce libellé ne décrit pas ses caractéristiques visuelles et doit être revu avec les contenus réels.

2. L'option SQL de réinitialisation détruit volontairement sa cible. La comparaison avec `DB_NAME` ne protège pas les autres bases, alias, droits ou concurrents ; le harnais shell SQL direct ne possède pas cette protection. Utiliser exclusivement un serveur jetable et sauvegarder.

3. Les données de démonstration versionnées, les journaux et les fonctions d'installation imposent une vérification de configuration et de sécurité avant mise en ligne. Aucun examen de l'historique complet ni des secrets hors index n'est revendiqué.

4. Lors de la préparation des tests facultatifs PHP-WASM, l'audit npm a signalé **9 vulnérabilités** (dont 5 élevées) dans l'outillage Node et ses dépendances, notamment `@php-wasm/node`. Ce n'est pas une analyse de l'application PHP en production ; la mise à niveau majeure n'a pas été entreprise dans cette correction. Ne pas exposer les outils de développement sur Internet ; examiner et mettre à jour ces dépendances dans une tâche dédiée.

5. Les contrôles lexicaux, de syntaxe et de conteneur ne remplacent ni audit de sécurité complet, ni revue métier, ni tests navigateur, ni campagne de recette sur l'hébergement. Les inclusions dynamiques et consommateurs externes peuvent échapper au scanner.

Auto-évaluation : points forts : corrections étayées par régressions isolées et nouveaux garde-fous bloquants ; faiblesses : revue manuelle ciblée plutôt qu'exhaustive, SQL et navigateur non disponibles localement, pas de garantie sur les environnements externes. À compléter par une recette réelle sur serveur MariaDB jetable puis sur l'hébergement cible.